SECURITY ASSESSMENT

Web application assessment, Orders portal

two weeks, grey-box

Prepared for	Example Logistics (fictional)
Classification	**Confidential**

Document control

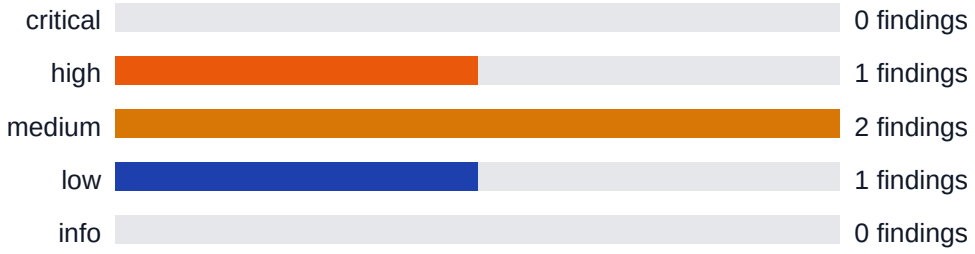
Type	Security assessment
Sources	S1 security.yaml `1297b305659b`
Generator	flow-tower report
Classification	Confidential

Contents

1 Summary
2 Scope
3 Methodology
4 Findings
5 Remediation
6 Appendix: sources

1 Summary

Findings by severity



Findings	4
Client	Example Logistics (fictional)
Window	two weeks, grey-box

2 Scope

- orders.example.test (web application and its REST API)
- auth.example.test (single sign-on)

3 Methodology

- Automated scan, then manual verification of every reported issue
- Manual testing of authentication, session handling and access control
- Scoring with CVSS v4.0 base metrics; severity from the CVSS qualitative bands

4 Findings

4 findings: 1 high, 2 medium, 1 low

high `V-01 orders.example.test /api/orders/export`

Order export reachable without authorization checks

Any signed-in customer can download every customer's orders by changing the account parameter.

Recommendation: Check on the server that the account in the request belongs to the session user.

Status: open

medium `V-02 orders.example.test`

Session cookie without SameSite attribute

The session cookie is sent on cross-site requests, which allows cross-site request forgery on state-changing forms.

Recommendation: Set SameSite=Lax (or Strict) and keep anti-CSRF tokens on forms.

Status: open

medium V-04 auth.example.test /reset

Password reset token valid for 7 days

Reset links stay valid for a week and are not invalidated after use.

Recommendation: Expire reset tokens after 30 minutes and invalidate them on first use.

Status: open

low V-03 orders.example.test

Verbose error pages reveal framework versions

Unhandled errors return a stack trace with framework and library versions.

Recommendation: Return a generic error page in production and log the detail server-side.

Status: fixed

5 Remediation

Id	Severity	Asset	Status
V-01	high	orders.example.test /api/orders/export	open
V-02	medium	orders.example.test	open
V-04	medium	auth.example.test /reset	open
V-03	low	orders.example.test	fixed

6 Appendix: sources

Id	Label	Location	SHA-256
S1	security.yaml	samples/security.yaml	`1297b305659b`